基于 Token 的身份认证与知识库问答

CampusClaw 实现方案

一、基于 Token 的身份认证

> 用户名和密码 → 签发 JWT → 请求携带 Bearer Token → 校验 JWT 与数据库授权记录 → 加载当前用户 → 按角色和班级授权

签发：app/routes.py 的 api_auth_token 校验用户名和密码，调用 app/auth.py 的 issue_access_token 生成短期 HS256 JWT；app/models.py 的 AuthToken 保存 jti、用户和过期时间。JWT 含 sub、jti、iat、nbf、exp、iss、aud 与 access 类型。

校验：app/routes.py 的 load_logged_in_user 从 Authorization: Bearer 请求头取 Token；app/auth.py 的 authenticate_access_token 验证 JWT、未撤销的授权记录，并重新读取数据库 User。缺失或失效时返回 401。

授权与登出：routes.py 的 teacher_required 根据数据库 role 限制上传；资料与问答用 g.user.class_id 限定本班。api_auth_logout 撤销当前 Token；app/static/js/auth.js 将 Token 保存在当前标签页的 sessionStorage，并为 API 请求添加 Bearer 请求头。

二、基于知识库的问答

> 教师上传资料 → 保存正文并分块 → 建立 SQLite FTS5 索引 → 按当前用户班级召回相关片段 → 发送编号来源给智谱模型 → 校验引用并返回回答

建库：app/models.py 的 Material.create_from_upload 保存 UTF-8 资料和 KnowledgeEntry；app/retrieval.py 的 chunk_text 按行切分，replace_entry_index 将 KnowledgeChunk 写入 SQLite FTS5 trigram 索引。

检索：app/qa.py 的 retrieve_answer_sources 提取词项、结合 FTS 与正文匹配排序、去重，最多取 4 个来源。查询用数据库用户的 class_id 同时约束分块和资料；无命中时 answer_question 直接返回本地提示。

生成：routes.py 的 api_knowledge_answer 调用 qa.py 的 answer_question；build_messages 将问题和编号来源组成提示词，ZhipuClient 使用用户本次提交的 API Key 调用智谱。Key 不持久化。

返回：qa.py 的 parse_answer 检查回答内容和 [N] 引用编号。结果包含答案与来源；routes.py 的资料详情和下载接口会再次校验当前用户的班级权限。